

Northstar Analytics
Security Incident Response Policy
Owner: Security and Compliance Team

Overview

This policy describes how Northstar Analytics responds to suspected security incidents involving company systems, employee accounts, customer data, or third-party integrations.

What Counts as a Security Incident

Examples include lost devices containing company data, suspicious login activity, malware alerts, accidental exposure of credentials, customer reports of unauthorized access, and unexpected changes to production access permissions.

Reporting Window

All employees and contractors must report a suspected security incident within one hour of discovery. Reports should be sent through the incident hotline form and posted in the security incident channel if the issue affects active operations.

Initial Response

The first responder should collect basic details without altering evidence. Important details include who reported the issue, when it was discovered, the systems involved, visible symptoms, and whether customer data may be affected. If credentials are exposed, access should be rotated as quickly as possible.

Severity Levels

Severity 1 incidents involve confirmed unauthorized access, production data exposure, ransomware, or service disruption affecting multiple customers. Severity 2 incidents include malware on an internal device, suspicious but unconfirmed account activity, and accidental internal data sharing. Severity 3 incidents include low-risk policy violations with no sign of external compromise.

Containment Actions

Containment may include disabling accounts, revoking active sessions, isolating endpoints from the network, rotating secrets, or temporarily disabling risky integrations. The incident commander decides which actions are necessary based on risk and business impact.

Communication Requirements

Internal updates should be posted every 30 minutes for Severity 1 incidents and every 60 minutes for Severity 2 incidents until the situation is stable. Customer communication must be coordinated with legal, security, and customer success leadership.

Post-Incident Review

Every Severity 1 and Severity 2 incident requires a written post-incident review within five business days. The review must capture root cause, timeline, impact, corrective actions, and owners for follow-up tasks.